

Actividad 3 - Cross Site Scripting (XSS).

Auditoria Informática.

Ingeniería en Desarrollo de Software

Tutor: Jessica Hernández.

Alumno: Gerardo Rojo.

Fecha: 20/10/2024

Contenido

Introducción 1

Descripción 1

Justificación 1

Etapa 1..... 2

 Descripción del sitio web 2

 Ataque al sitio Web..... 3

Etapa 2..... 5

 Ataque al sitio 6

Etapa 3..... 12

 Ataque al sitio 12

Conclusiones..... 16

Referencias 16

Introducción.

En el ámbito de la seguridad informática, la empresa de software a la que le hemos estado trabajando en esta materia, ha identificado la necesidad urgente de realizar exhaustivas pruebas de seguridad en diversas páginas web que actualmente carecen de medidas de protección y protocolos adecuados. Estas páginas web, al no contar con los candados de seguridad necesarios, son muy vulnerables a una variedad de ataques cibernéticos que podrían comprometer la integridad y confidencialidad de los datos de los usuarios. La realización de este tipo de pruebas de seguridad es fundamental para poder garantizar que las páginas web puedan resistir ataques maliciosos y proteger adecuadamente la información de los usuarios, o cual quiera que sean los datos que se alojan dentro de las bases de datos de dichas páginas. Al identificar y corregir las vulnerabilidades, la empresa de software no solo mejora la seguridad de sus aplicaciones, sino que también refuerza la confianza de sus usuarios en la protección de sus datos personales. Punto crítico para que estos usuarios sigan prefiriendo el uso de estas páginas web.

Descripción.

En esta tercera fase del proyecto de seguridad, se ha solicitado específicamente llevar a cabo una prueba de vulnerabilidad de Cross Site Scripting (XSS). El objetivo principal de esta prueba es interceptar y obtener las credenciales que los usuarios ingresan durante el proceso de inicio de sesión. Esta etapa es crucial, ya que las credenciales de inicio de sesión son uno de los puntos más sensibles y críticos en la seguridad de cualquier sistema web. Para llevar a cabo esta prueba, se utilizará la herramienta Burp Suite, una plataforma integral para pruebas de seguridad de aplicaciones web. Con Burp Suite, se procederá a capturar y analizar el tráfico de datos entre el cliente y el servidor. Una vez obtenida la información de las credenciales, se modificará esta información para comprobar si es posible acceder al sistema con las credenciales interceptadas. Este proceso no solo ayudará a identificar la vulnerabilidad, sino que también permitirá evaluar la efectividad de las medidas de seguridad implementadas y determinar las acciones correctivas necesarias para fortalecer la protección del sistema.

Justificación.

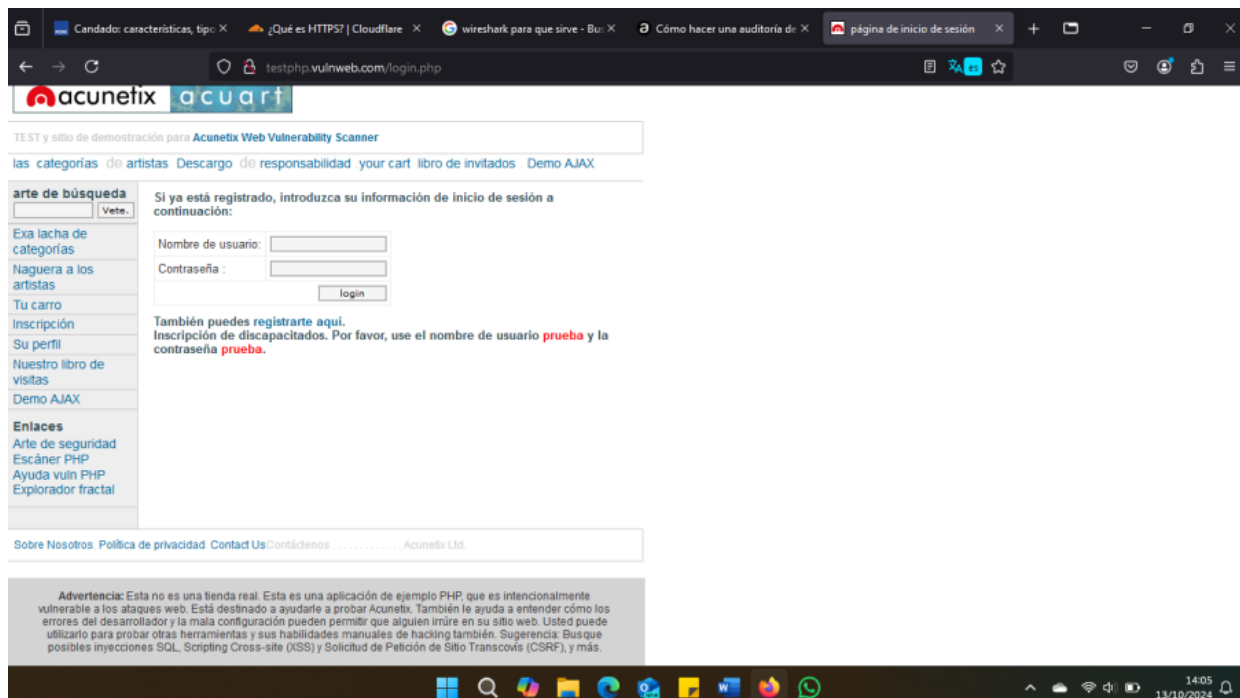
Realizar pruebas de Cross Site Scripting (XSS) en páginas web es crucial para garantizar la seguridad de las aplicaciones y la protección de los datos sensibles de los usuarios. Estas pruebas permiten identificar y mitigar vulnerabilidades que podrían ser explotadas por atacantes para robar información confidencial, manipular contenido o redirigir a los usuarios a sitios maliciosos. Además, ayudan a cumplir con normativas y estándares de seguridad como el OWASP Top Ten, demostrando el compromiso de la organización con la protección de la información. La detección y corrección de vulnerabilidades de XSS fortalece la resiliencia del sistema frente a ataques cibernéticos, protege la reputación de la empresa y reduce riesgos legales asociados a brechas de seguridad. Las pruebas de XSS son esenciales para mantener la integridad y confianza en las aplicaciones web, asegurando que los datos de los usuarios estén protegidos y que la plataforma sea confiable y segura. Al implementar estas pruebas, las organizaciones no solo mejoran su postura de seguridad, sino que también refuerzan la confianza de sus usuarios y cumplen con las normativas de seguridad vigentes, minimizando así los riesgos de incidentes de seguridad y posibles litigios.

Etapa 1.

Una vez que tenemos ubicada la página con las características mencionadas, haremos uso de una herramienta especializada en auditorías Web, hablamos de Wireshark, es un analizador de paquetes de red, una utilidad que captura todo tipo de información que pasa a través de una conexión.

Descripción del sitio web.

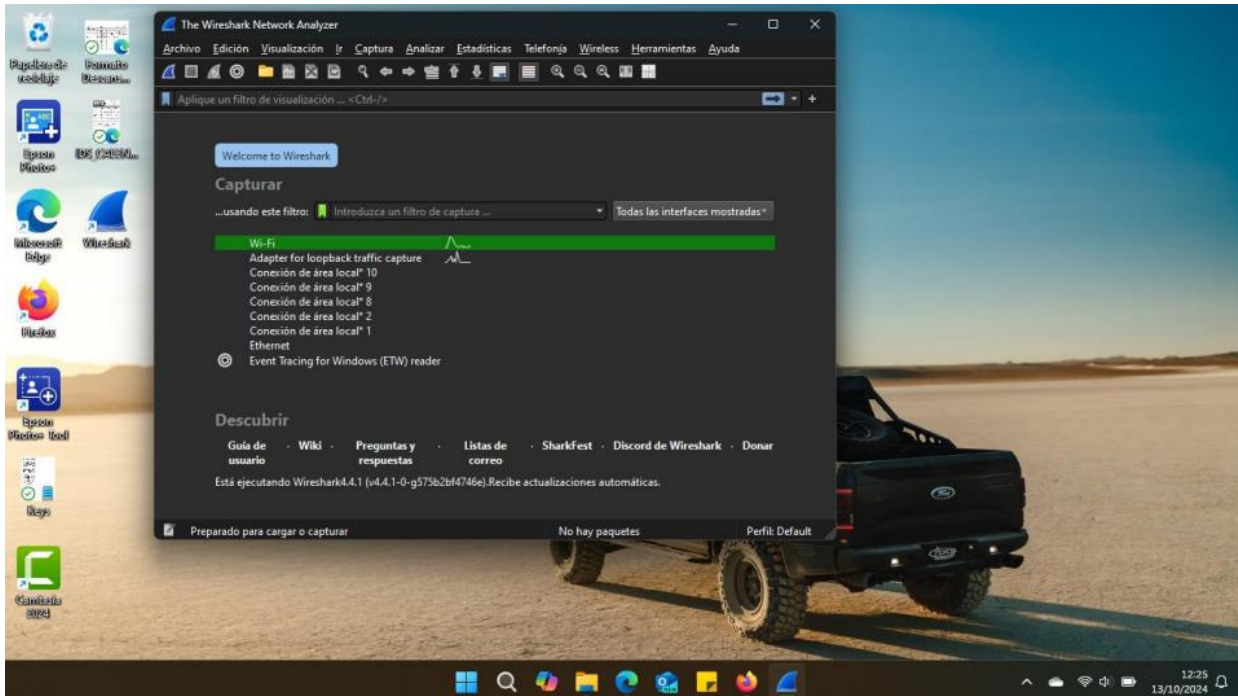
El sitio que necesitaremos para la realización de esta práctica debe cumplir con ciertas características, como lo es que debe utilizar solo el protocolo HTTP que como se menciona dentro de la descripción. HTTP es un protocolo basado en el principio de cliente-servidor: las peticiones son enviadas por una entidad: el agente del usuario (o un proxy a petición de uno). La mayoría de las veces el agente del usuario (cliente) es un navegador Web, pero podría ser cualquier otro programa, como por ejemplo un programa robot, que explore la Web, para adquirir datos de su estructura y contenido para uso de un buscador de Internet. Aunque la versión del protocolo HTTP/2 añade algo de complejidad, al utilizar un formato en binario, esto aumenta su rendimiento, y la estructura y semántica de los mensajes es la misma desde la versión HTTP/1.0. El flujo de comunicaciones en una sesión es sencillo y puede ser fácilmente estudiado e investigado con un simple monitor de mensajes HTTP.



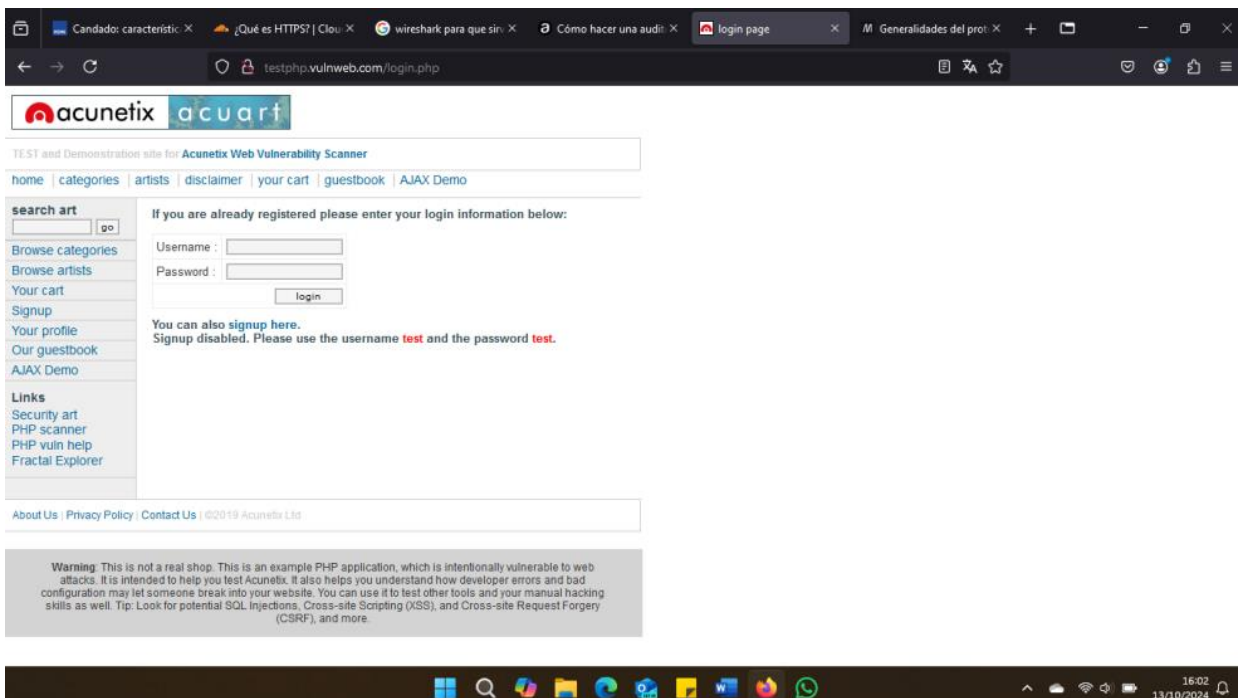
Como bien lo menciona la misma página WEB, se trata de un sitio web creado vulnerable de manera intencional destinado a realizar pruebas de vulnerabilidad precisamente, no es un sitio Web funcional. Está destinado a ayudarle a probar Acunetix principalmente, pero claro que se puede probar cualquier otra aplicación que permita realizar auditorías de vulnerabilidades dentro de los sitios Web. También le ayuda al desarrollador a entender cómo los errores de la programación y la mala configuración pueden permitir que alguien no autorizado irrumpa en su sitio web.

Ataque al sitio Web.

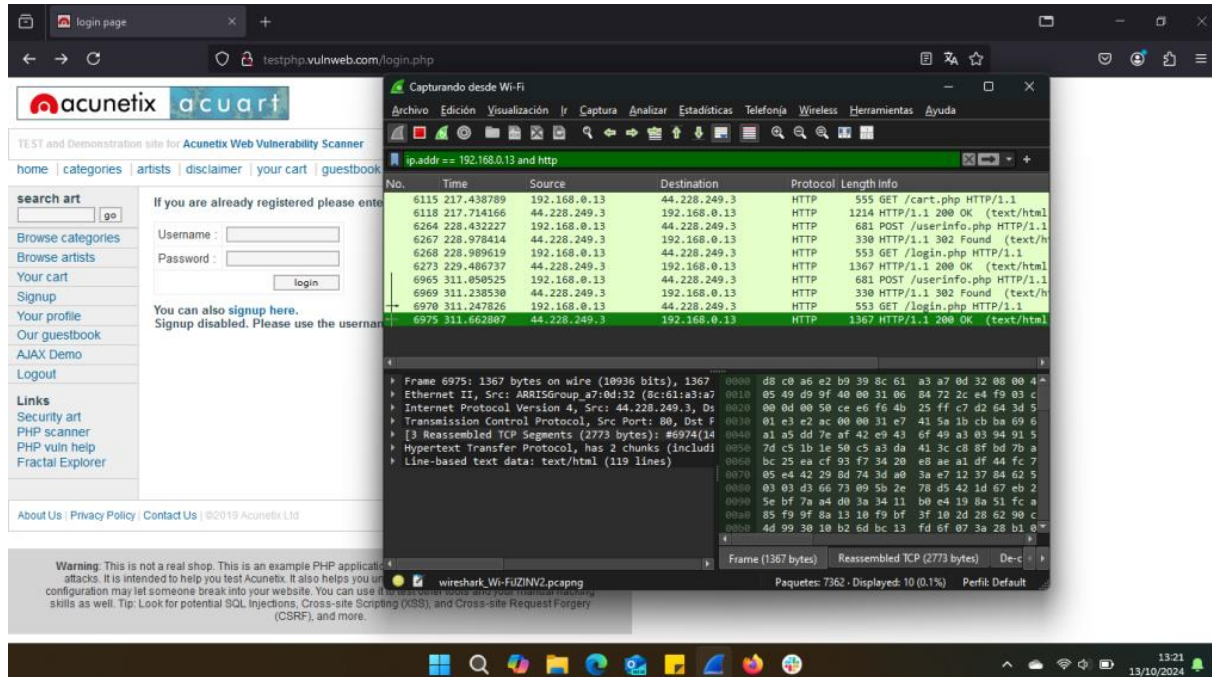
Antes de comenzar con el proceso para vulnerar las contraseñas tenemos que instalar el software que nos ayudara con este cometido, para esta práctica en particular utilizaremos WireShark.



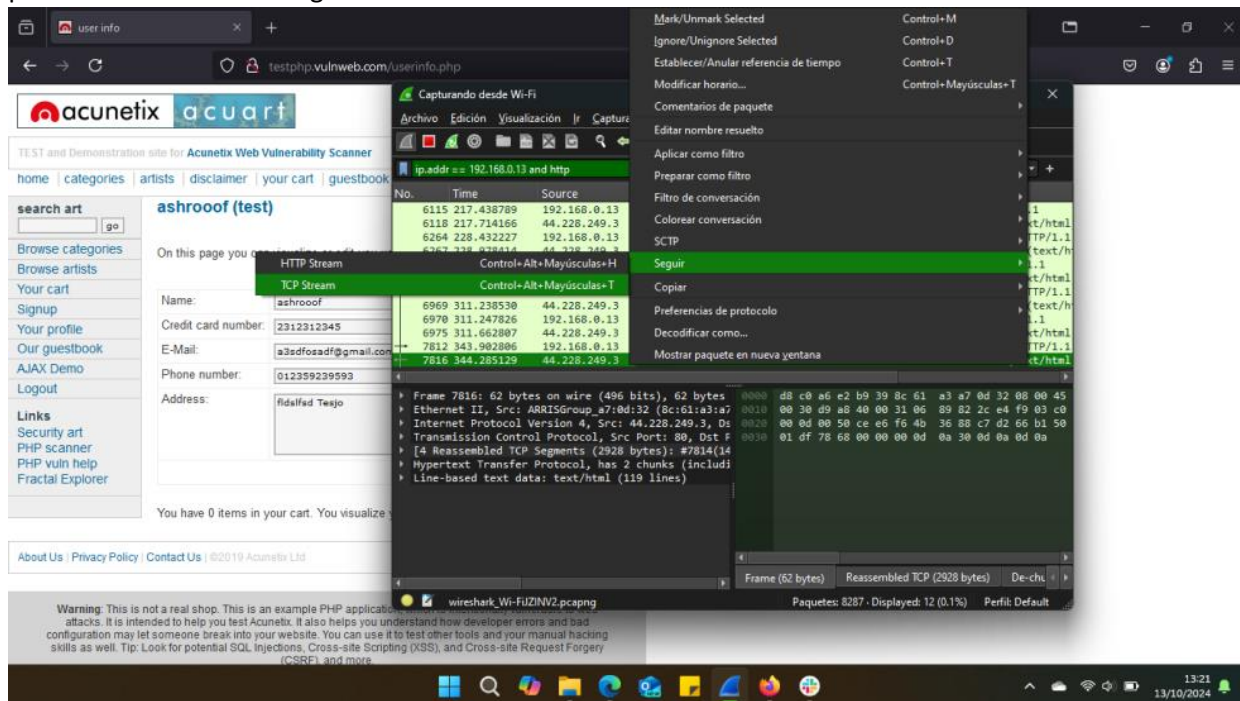
Esta es la interfaz principal que nos ofrece WireShark, sin duda tiene muchas herramientas que seguramente serán de gran utilidad de acuerdo a la situación en la que estemos haciendo uso de esta herramienta. Pero la que nos importa ahora mismo es la opción del monitoreo de red mediante Wifi.



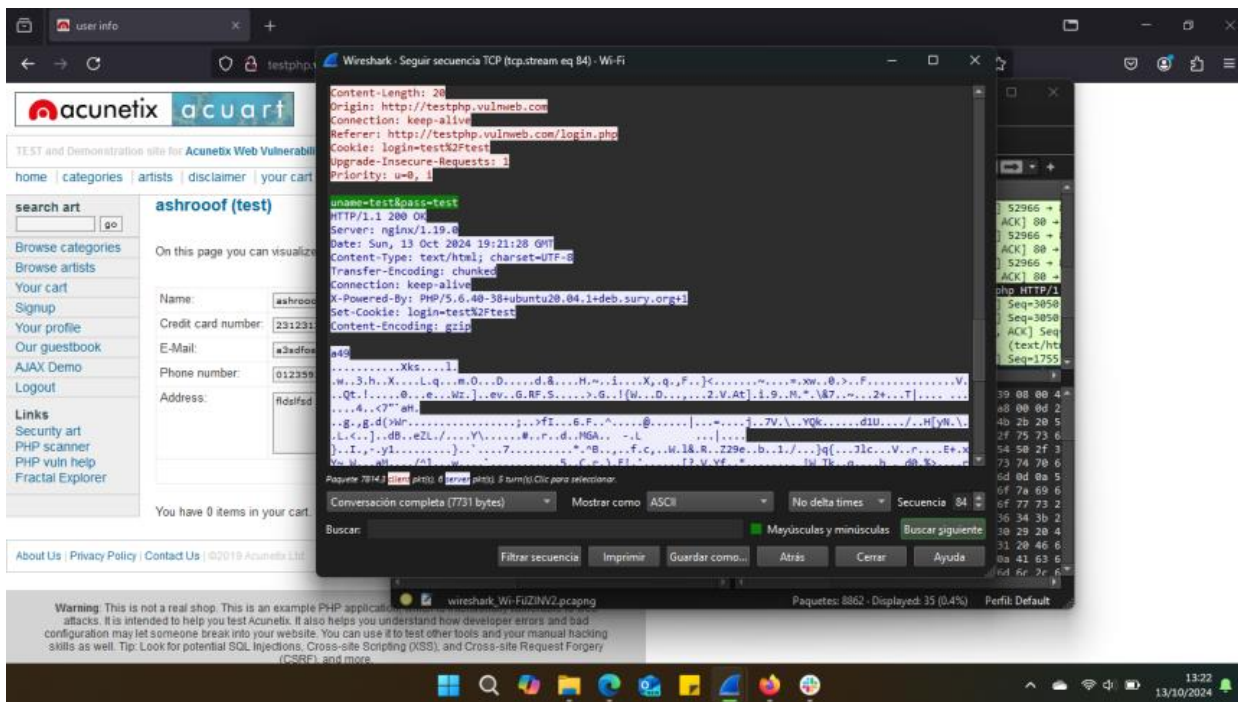
Ya instalada nuestra herramienta accedemos a la página de prueba para vulnerar las credenciales de usuario. Aquí tendremos que conseguir la dirección IP correspondiente a nuestro sitio web, WireShark nos puede ayudar con esto, basta con observar la actividad dentro de la aplicación.



Dentro de la aplicación de WireShark y sin cerrar nuestra página de prueba, colocamos la IP de nuestro sitio web acompañado de un filtro para que nos muestre la actividad exclusiva de este sitio, tal como se puede observar en la imagen.



Seleccionamos el ultimo evento registrado para esta IP que es justo el de inicio de sesión, damos clic derecho y seleccionamos "seguir" y seleccionamos "TCP Stream". Justo después de realizar lo anterior se nos mostrara la pantalla que mostraremos a continuación.



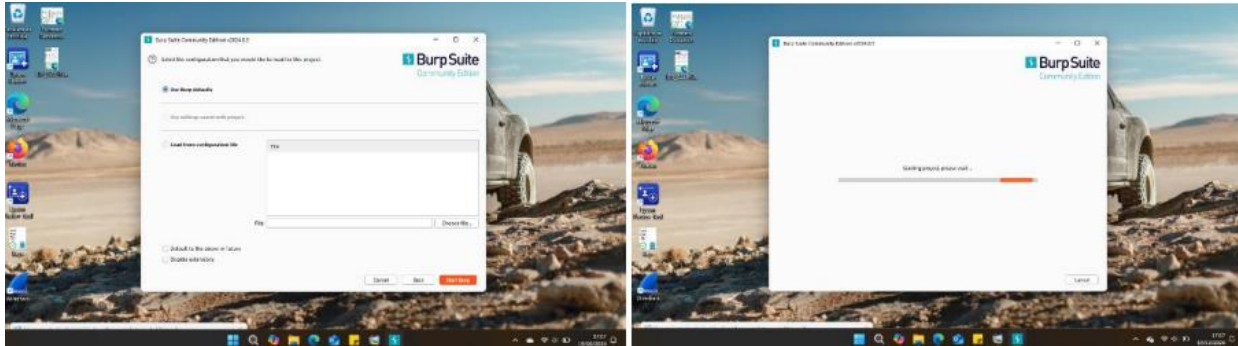
Es aquí donde en medio de todo el código que nos arroja encontraremos el nombre de usuario al igual que la contraseña ingresada al sitio para que este nos dé el acceso. En la imagen se ha resaltado en color verde las credenciales. Y como se puede observar son justo los datos que la misma página nos brinda como credenciales correctas.

Etapas 2.

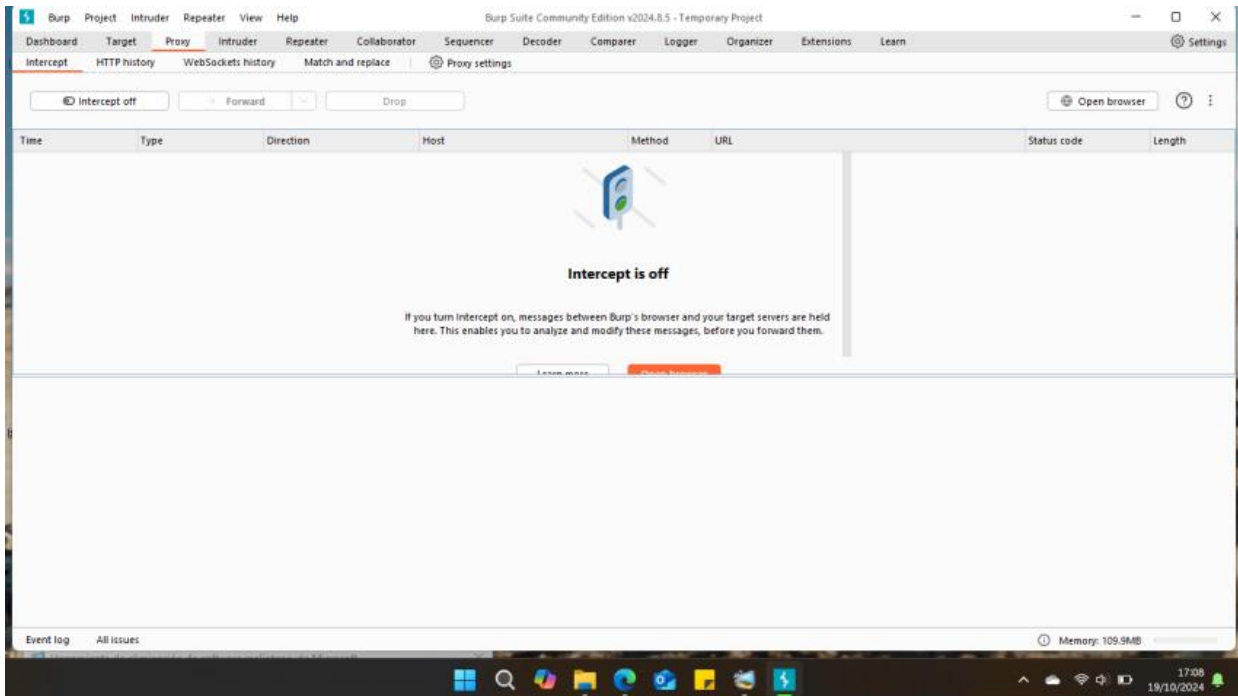
En este caso, la prueba se centrará en el uso de cookies como vector de ataque. Las cookies son pequeños fragmentos de datos que los sitios web almacenan en el navegador del usuario para mantener el estado de la sesión y otras informaciones relevantes. Para llevar a cabo esta prueba, se utilizará Burp Suite Community Edition, una herramienta ampliamente reconocida en el ámbito de la seguridad informática. Burp Suite permite a los profesionales de seguridad realizar pruebas de penetración y análisis de aplicaciones web de manera eficiente. El objetivo de esta prueba es iniciar sesión en la página web como un usuario normal y, mediante la manipulación de las cookies, escalar privilegios para acceder al modo administrador. El proceso comenzará con la identificación de las cookies relevantes que se generan al iniciar sesión como un usuario estándar. Luego, se analizarán estas cookies para detectar posibles puntos de deserialización insegura. Utilizando las funcionalidades de Burp Suite, se intentará modificar las cookies de manera que se obtengan privilegios de administrador. Este tipo de prueba es crucial para asegurar que las aplicaciones web implementen correctamente las medidas de seguridad necesarias para proteger los datos y la integridad del sistema.

Ataque al sitio.

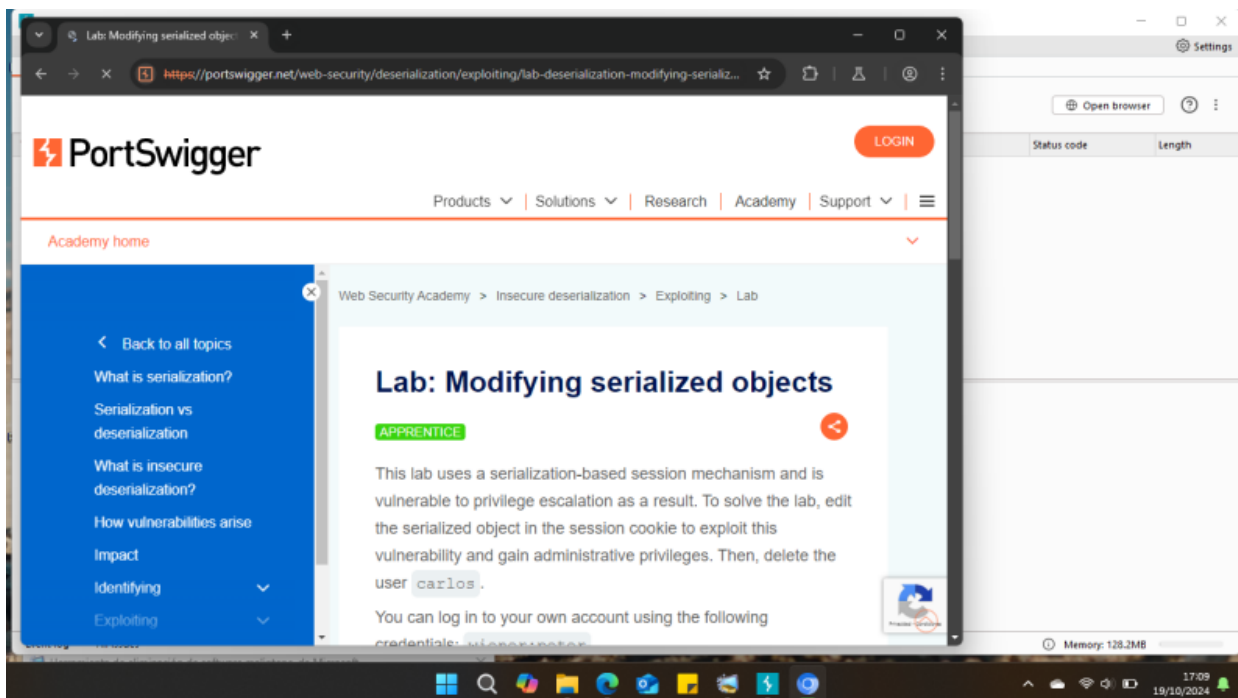
Pues bien, ha llegado el momento de comenzar con la preparación para el ataque al sitio que se nos solicita, como ya se mencionó dentro de la descripción de esta actividad, ingresaremos a un sitio de pruebas con el usuario y la contraseña que la misma página nos proporciona, una vez registrados interceptaremos la comunicación entre la página y el servidor con ayuda de Burp con el fin de modificar la cookie que contiene nuestra información de usuario y con esto darnos los privilegios de administrador. Para poder confirmar que tenemos los derechos eliminaremos un usuario ya existente dentro de la base de datos de la página.



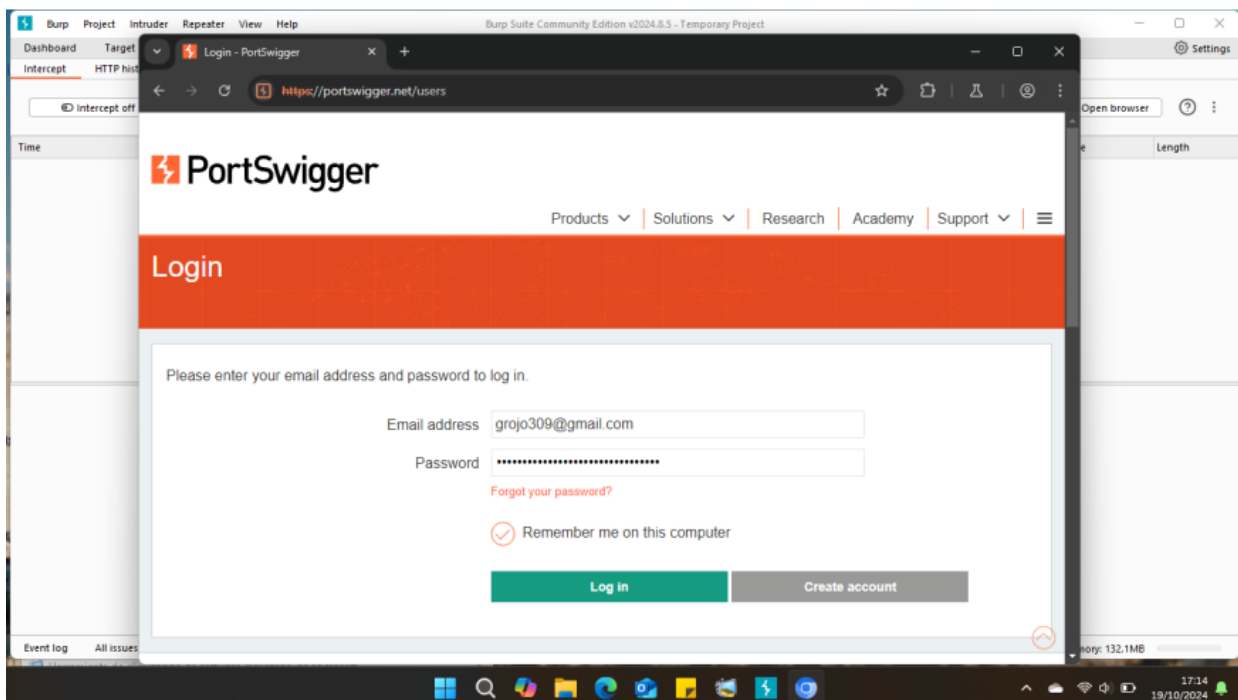
El proceso para crear un nuevo proyecto dentro de esta aplicación es sumamente sencillo, ya que de hecho solo dejaremos las opciones justo como están seleccionadas por defecto. Estas son las indicaciones que nos brinda la guía de la actividad proporcionada por la academia.



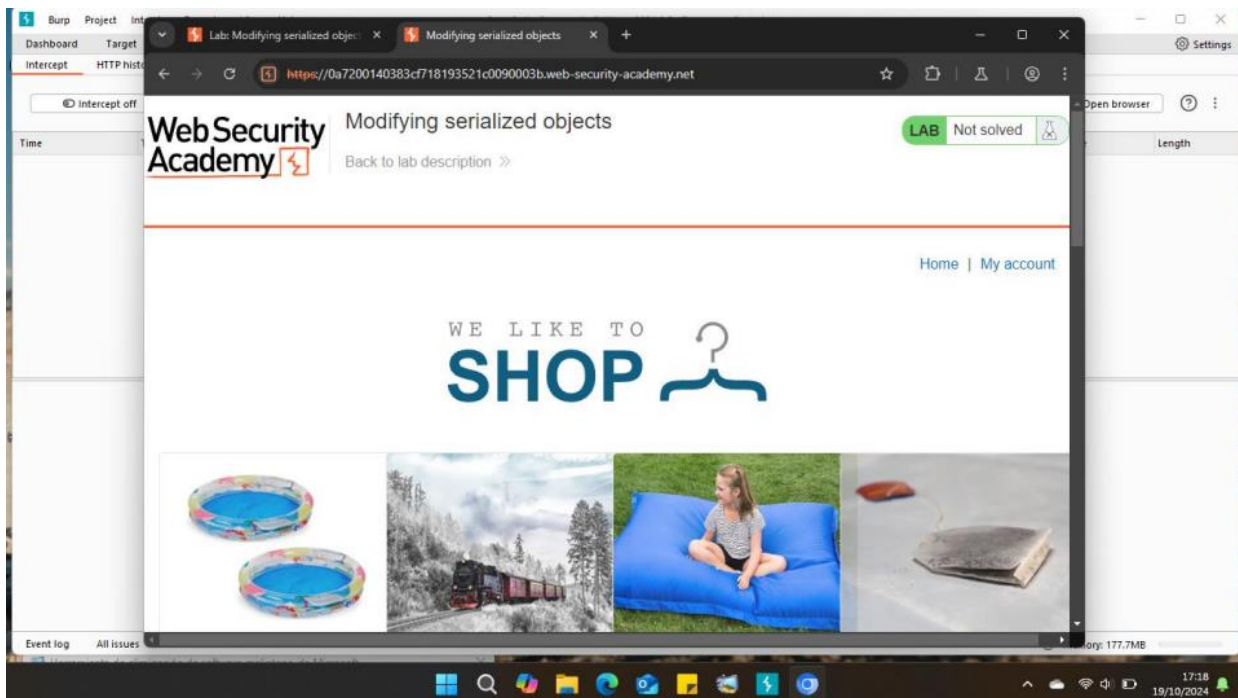
Nos dirigimos a la pestaña de “Proxi” y desde aquí daremos clic en el botón resaltado en color naranja, lo que abrirá una pestaña del navegador integrado de la aplicación.



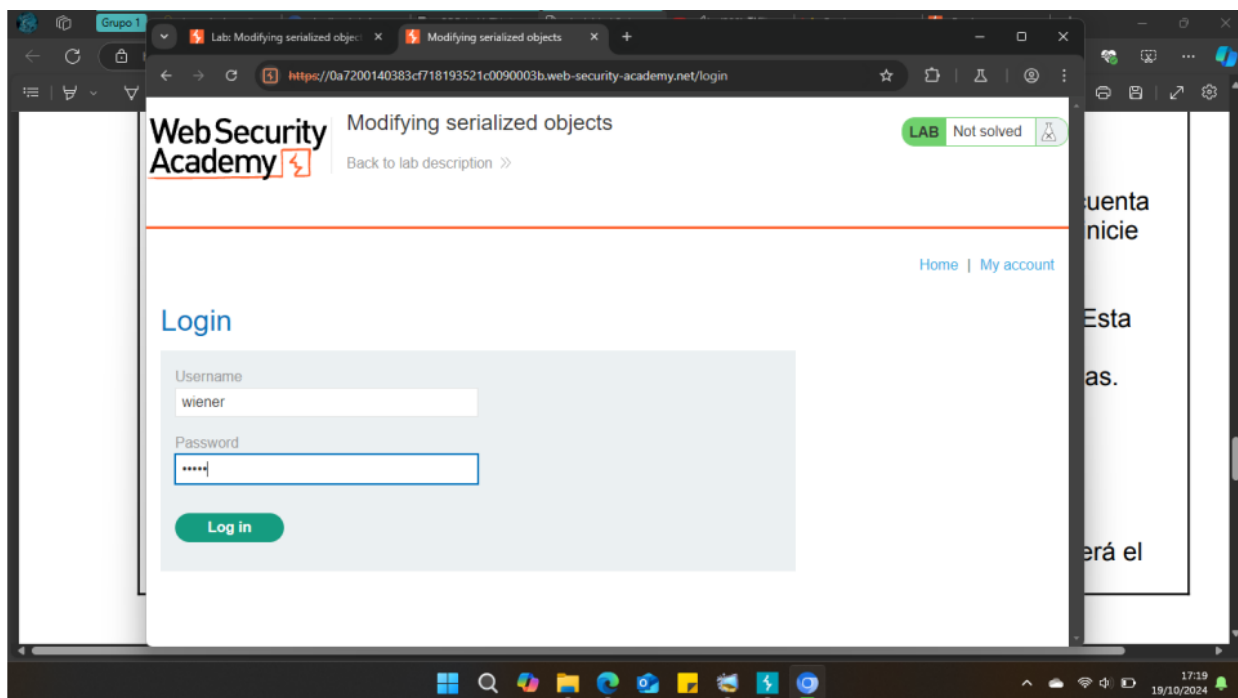
Dentro de esta nueva pestaña colocaremos la dirección URL del proyecto de deserialización, esta dirección es la que obtuvimos después de nuestro registro en la página de PortSwigger.



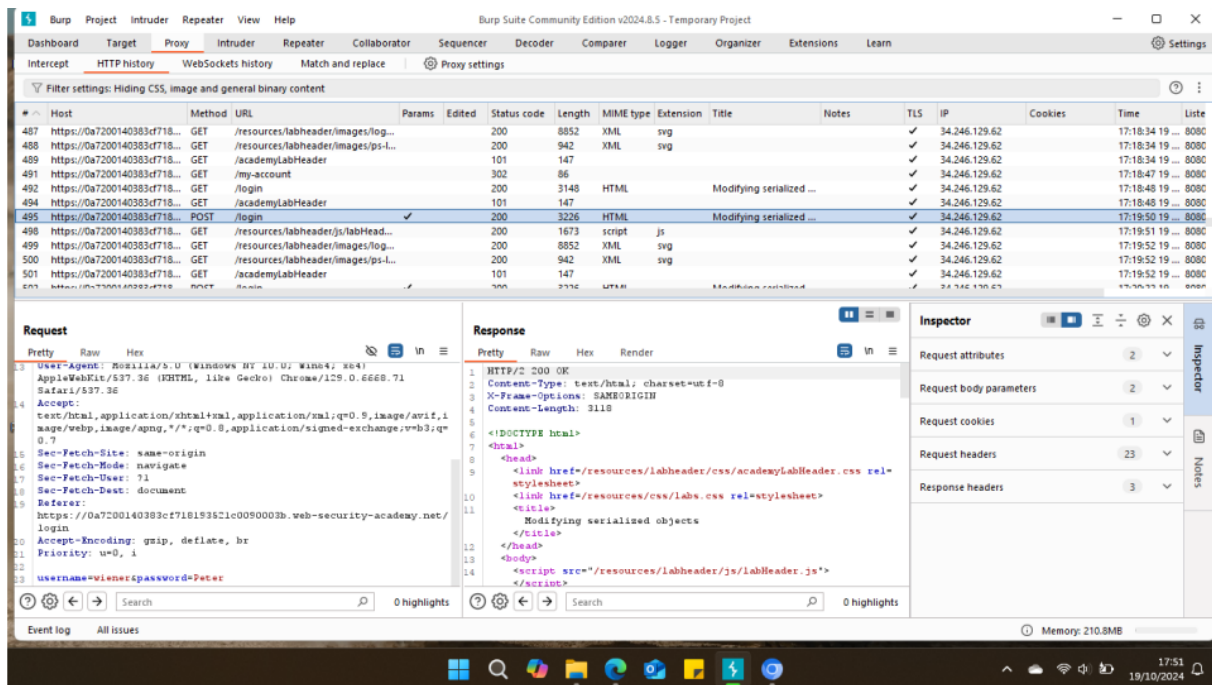
Entonces procedemos a iniciar sesión con nuestras credenciales que obtuvimos en el registro, esto para que nos permita realizar el proyecto de deserialización, ya que, si no nos registramos dentro de este nuevo navegador, simplemente no nos permitirá realizar la prueba.



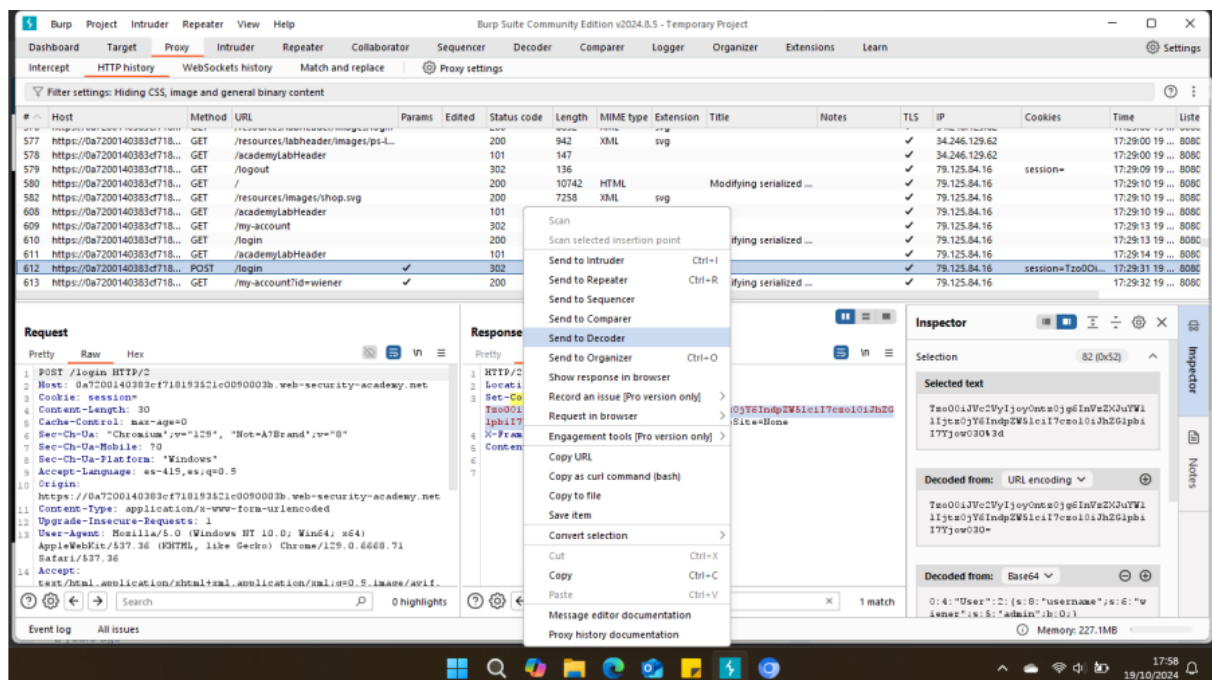
Ahora tenemos esta nueva pantalla, es qui donde hemos de comenzar con nuestro proceso de ataque, lo que debemos hacer en esta nueva pestaña es registrarnos con los datos que nos proporciona la descripción de la práctica, para esto damos clic en “my Account”.



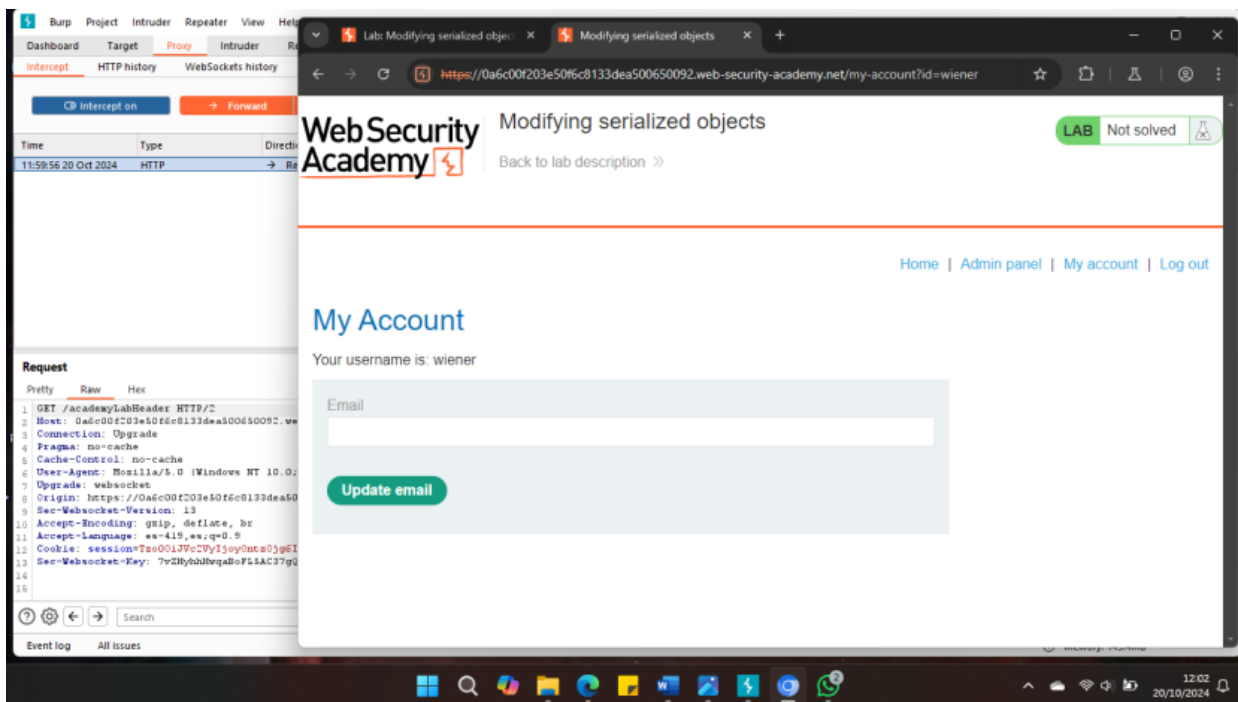
Nos envía a esta nueva pestaña en donde colocamos el usuario y la contraseña que se nos proporcionan en la descripción de la actividad. Usuario: Wiener, Contraseña: Peter.



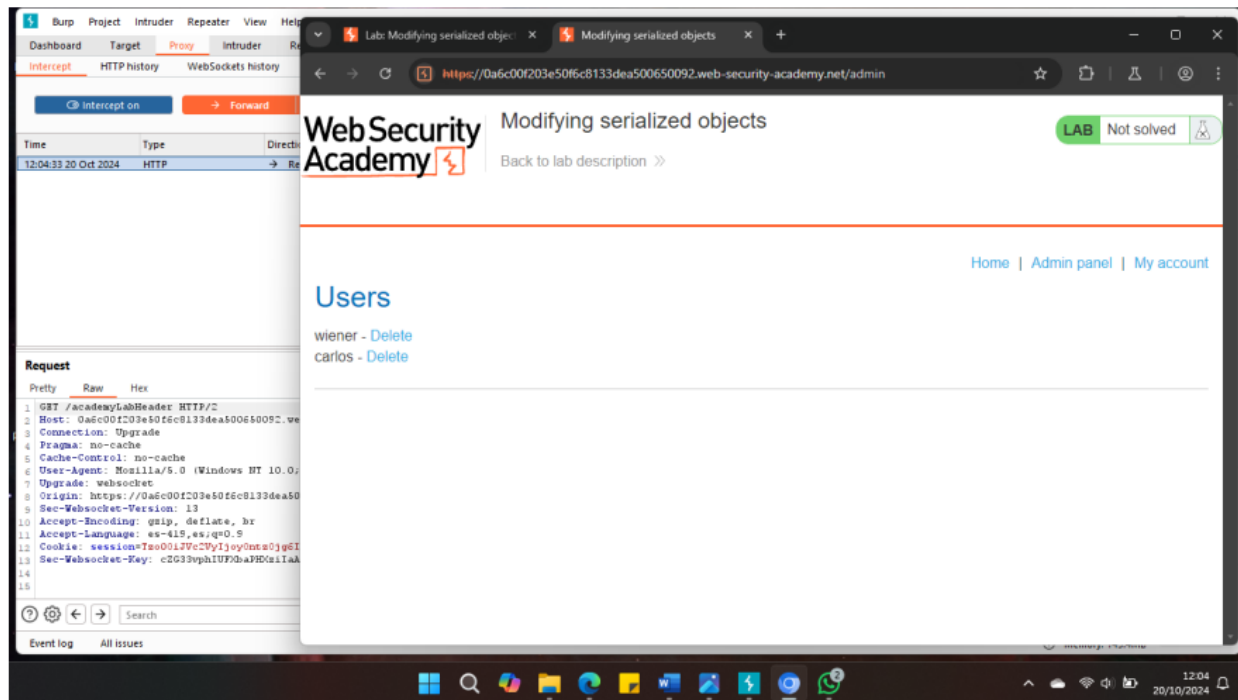
Una vez que damos clic a log in se genera un evento que se registra dentro del historial de HTTP, esto dentro de nuestra aplicación de Burp. Es aquí donde buscaremos el evento que contiene la cookie de nuestro inicio de sesión, entonces la seleccionaremos y editaremos con el fin de obtener permisos de administrados con la cuenta básica que hemos ingresado.



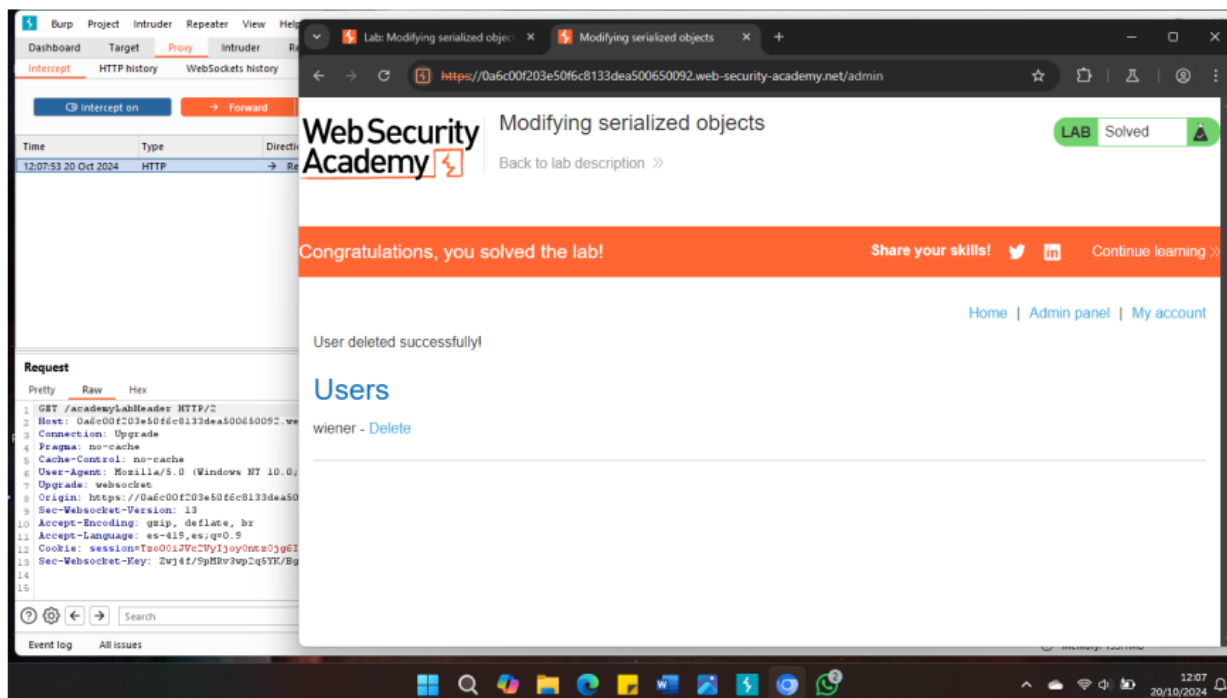
Seleccionamos la cookie que contiene la información de nuestro inicio de sesión, evento que ha quedado registrado justo después de iniciar sesión dentro de la página de la prueba. Compartimos la cookie con el decodificador que viene integrado dentro de la misma herramienta de Burp.



Ahora dentro de nuestro navegador las opciones han cambiado, pues ahora tenemos permisos de administrador, entraremos a este nuevo menú para poder eliminar al usuario que se nos solicita.



Cada que demos un clic dentro de las opciones del navegador tendremos que repetir el proceso de reemplazar la cookie que se genera, pues recordemos que el usuario con el que ingresamos no tiene permisos administrativos, y es ahí donde entra el papel del Interceptor.

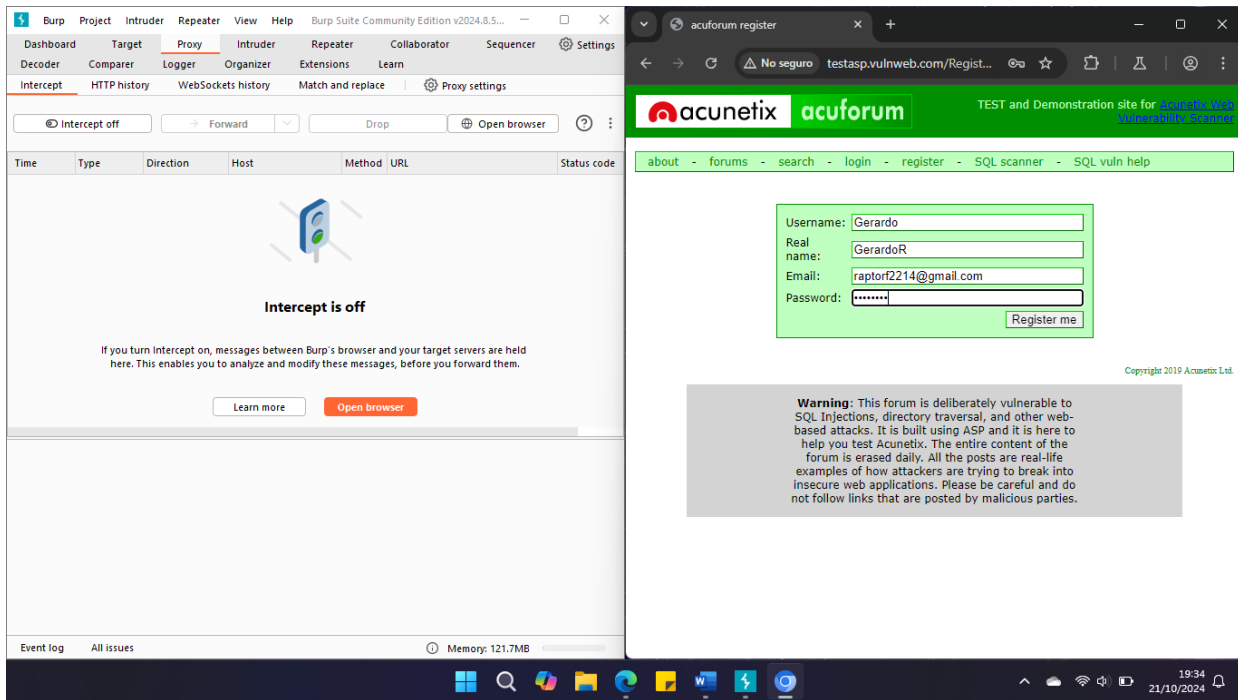


Eliminamos entonces al usuario que se nos solicita, y como se menciona, cada que seleccionemos una de las opciones dentro del navegador que necesite permisos de administrador tendremos que sustituir la cookie que se genera por la que hemos editado en el Decoder para otorgarnos los permisos correspondientes. Y como lo muestra la captura anterior, hemos eliminado correctamente el usuario que se nos solicita y ahora el indicador en la parte superior derecha ha cambiado a “Solved”. Lo que significa que la practica ha finalizado exitosamente.

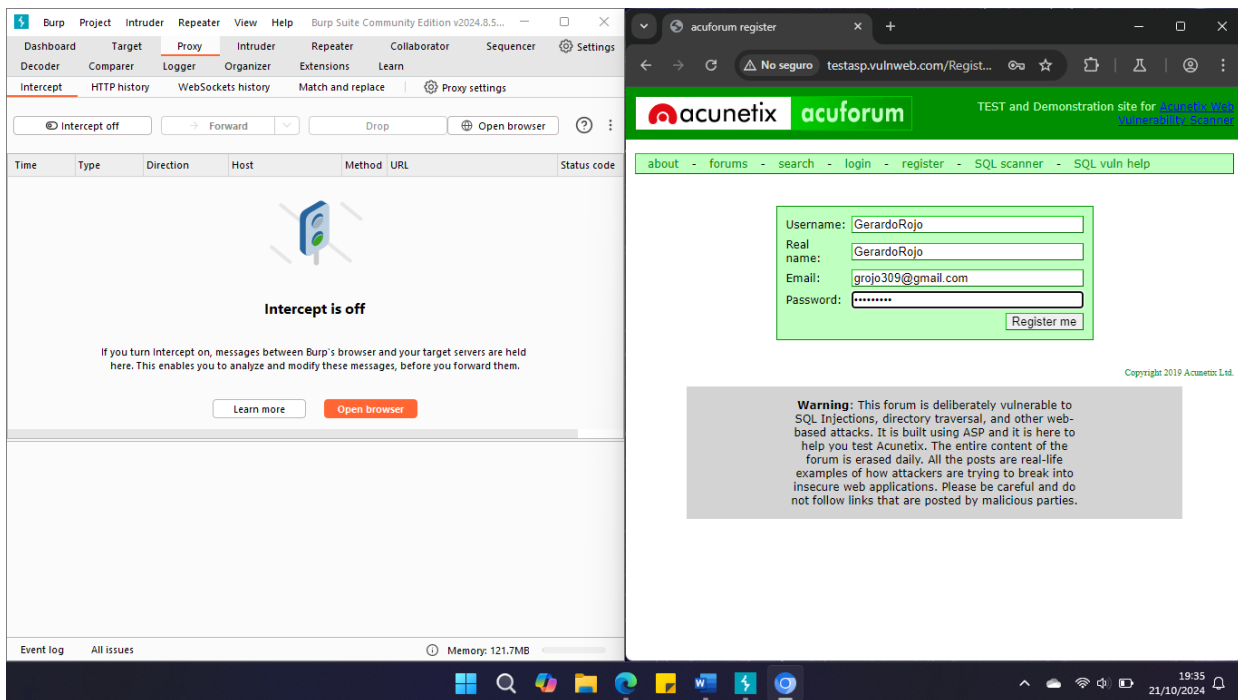
Etapa 3.

Es aquí donde comenzaremos con la realización de la tercer actividad, que no es más que un complemento a las actividades previas que hemos ya realizado, pues se nos sugiere utilizar nuevamente la primer pagina con seguridad débil para que pueda ser vulnerada, y la herramienta que nos ayudara a esto, será la herramienta que utilizamos dentro de la segunda actividad para captar la cookie del inicio de sesión, hablamos de Burp. una plataforma integral para pruebas de seguridad de aplicaciones web. Con Burp Suite, se procederá a capturar y analizar el tráfico de datos entre el cliente y el servidor. Una vez obtenida la información de las credenciales, se modificará esta información para comprobar si es posible acceder al sistema con las credenciales interceptadas. Este proceso no solo ayudará a identificar la vulnerabilidad, sino que también permitirá evaluar la efectividad de las medidas de seguridad implementadas y determinar las acciones correctivas necesarias para fortalecer la protección del sistema.

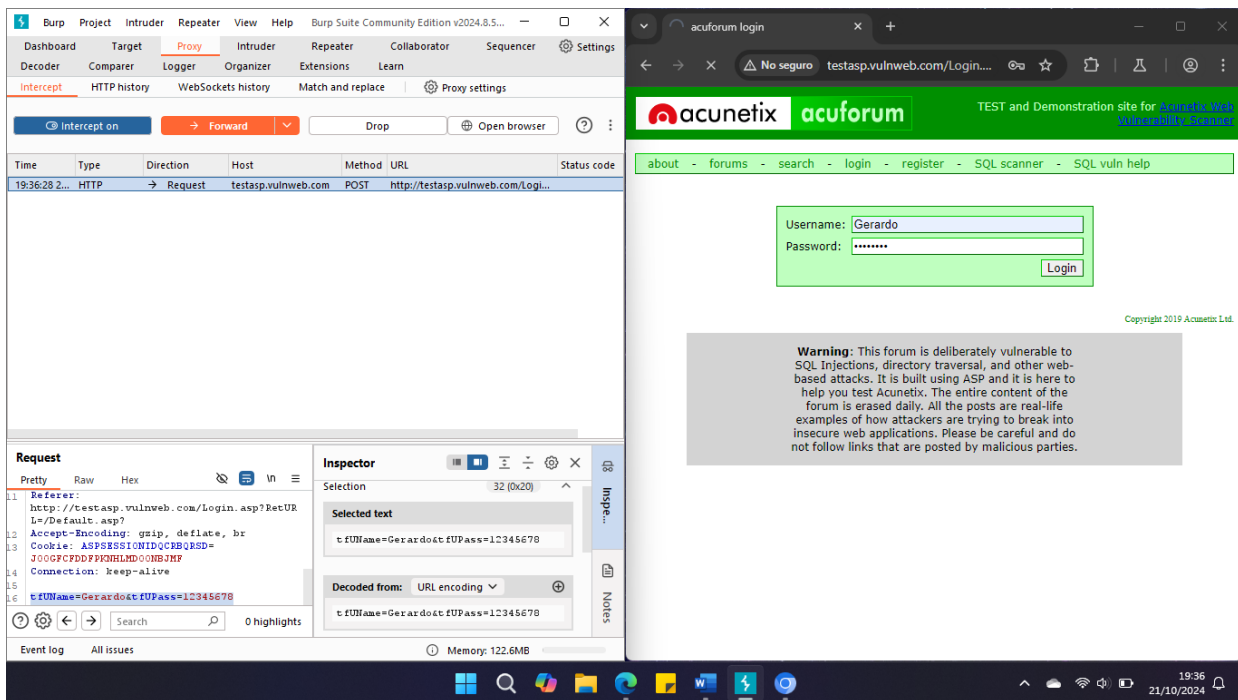
Ataque al sitio.



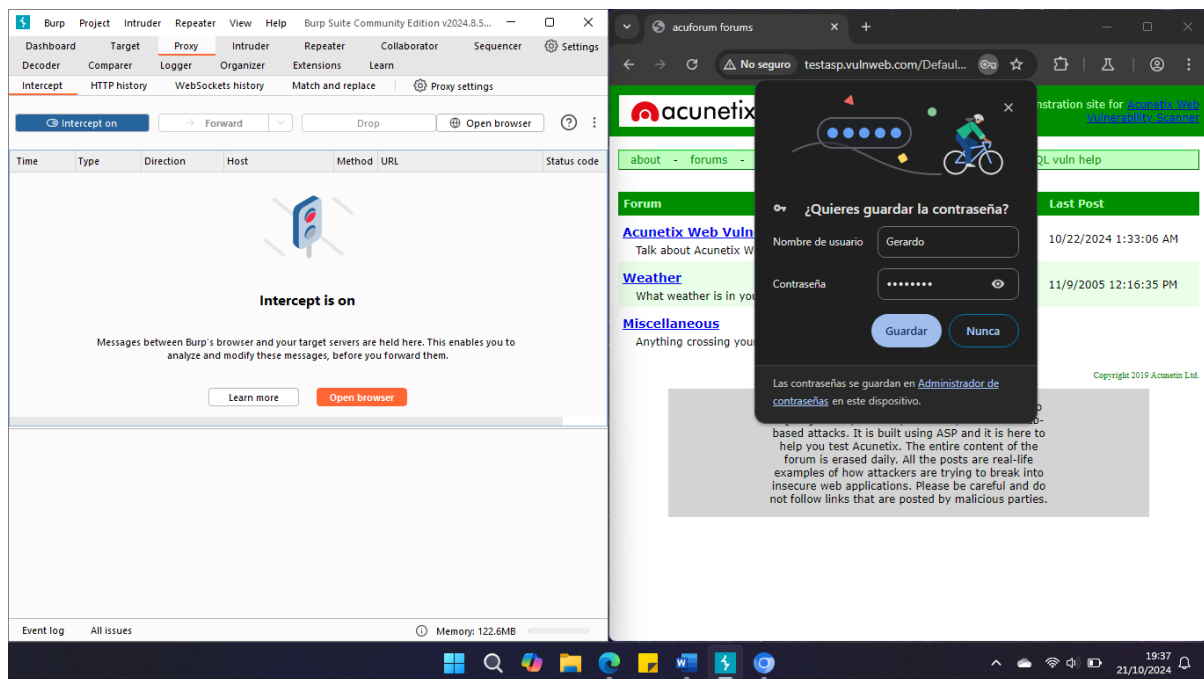
Generaremos dos registros con todos los datos que se nos solicitan, esto con el fin de poder comprobar si después de interceptar los datos ingresando otro usuario nos permite el acceso a la página web.



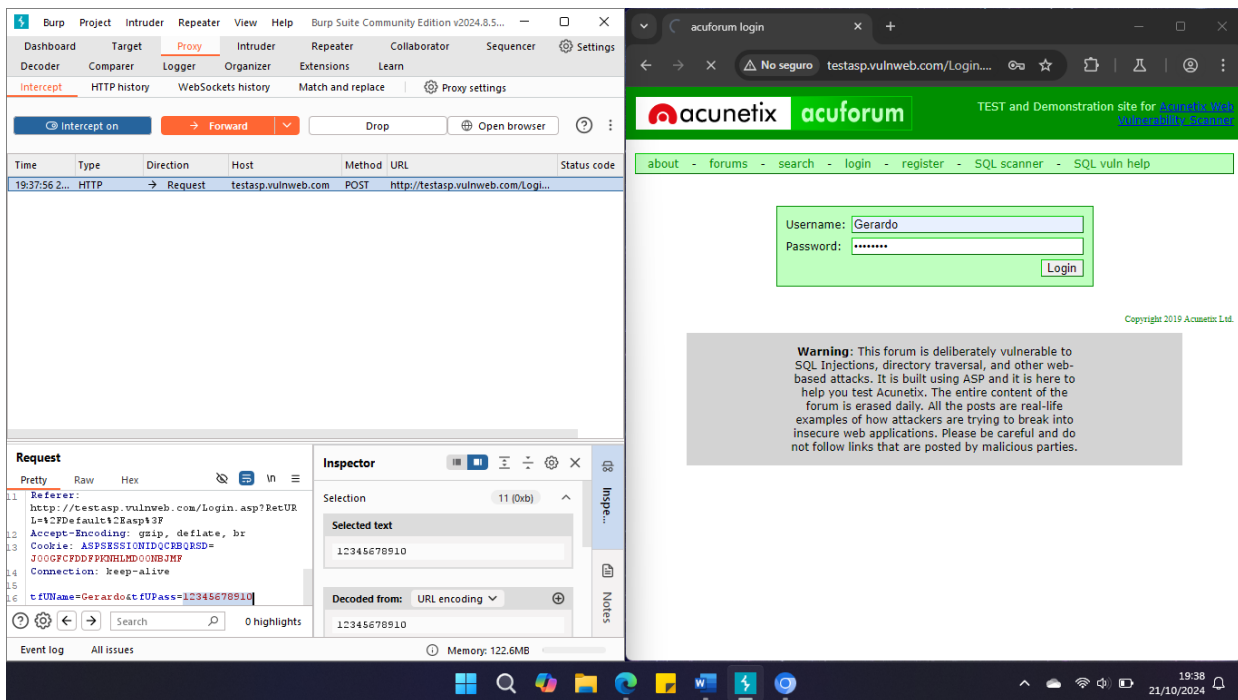
Este es el segundo registro dentro de la página web que también es una página creada de forma vulnerable a propósito con el fin de realizar pruebas de vulnerabilidad.



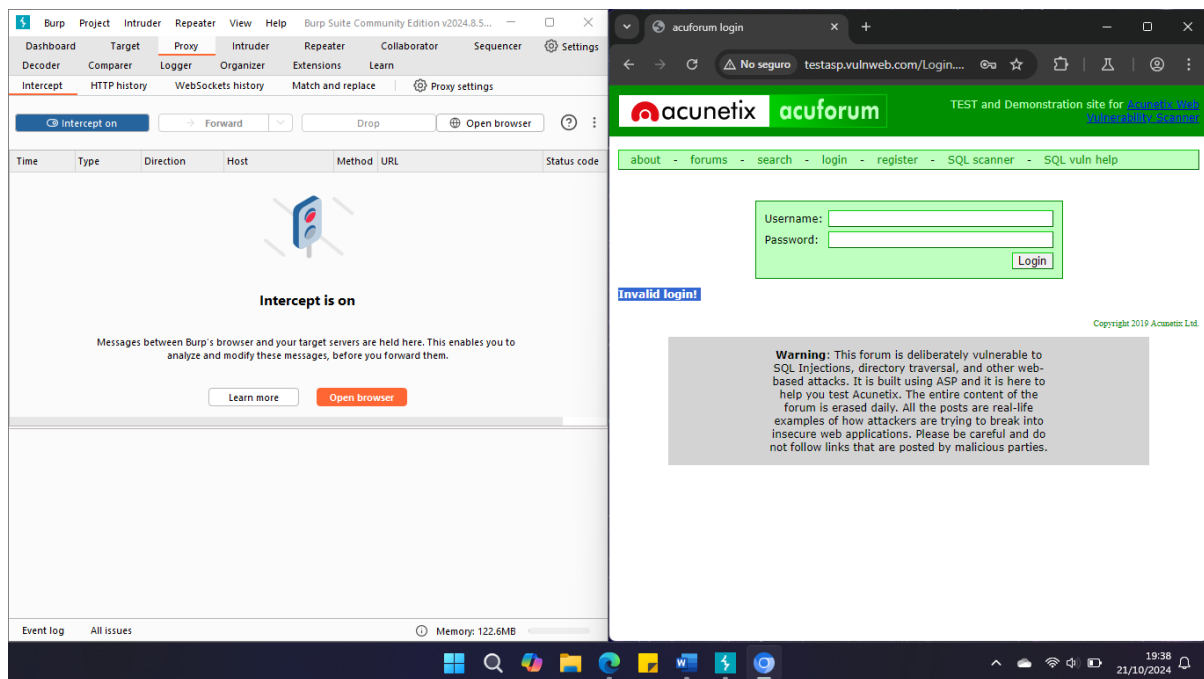
Con el Interceptor habilitado dentro de Burp procedemos a iniciar sesión dentro de la pagina web con las credenciales correctas, justo después de dar click a Login Burp capta la solicitud de conexión con el servidor, desde este punto ya podemos observar que nos muestra las credenciales utilizadas, el nombre del usuario y la contraseña con la que se está iniciando sesión.



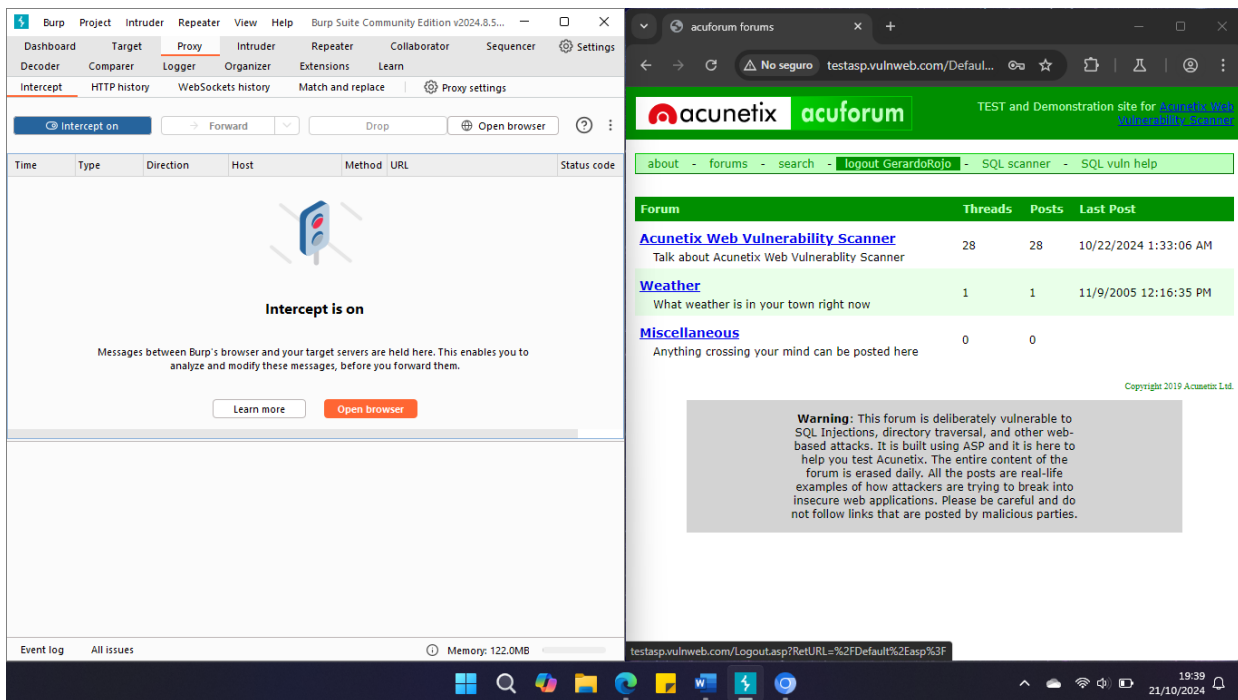
Al ser las credenciales correctas después de dar click en Forward se autoriza la conexión y se inicia sesión correctamente, incluso el navegador sugiere guardar las credenciales para no tener que recordarlas.



Justo como lo indica la práctica, modificaremos los datos de inicio de sesión desde Burp, para ello iniciaremos sesión nuevamente con los datos correctos, pero esta vez justo después de interceptarse la conexión, alteraremos la contraseña y daremos click en Forward.



Y como era de esperarse la pagina nos devuelve un mensaje de que la sesión es invalida, debido a que pese a que se ingresaron los datos correctos en un principio, dichos datos fueron alterados por Burp.



Se realiza el mismo proceso de intercepción, pero esta vez en lugar de ingresar datos erróneos, se ingresan los datos del segundo registro que se realizó, y al dar click a forward la página inicia sesión con los datos ingresados, si no con los que se colocaron después de la intersección. Y con esto damos por concluido nuestro proyecto de esta materia.

Conclusiones.

La realización de pruebas de vulnerabilidad XSS utilizando Burp Suite es una herramienta fundamental para evaluar la seguridad de aplicaciones web, permitiendo a los profesionales de la seguridad identificar y mitigar riesgos potenciales que podrían comprometer la integridad y confidencialidad de la información. Esta herramienta líder en el mercado ofrece una amplia gama de funcionalidades, incluyendo la detección automática de vulnerabilidades, el análisis exhaustivo de solicitudes y respuestas HTTP, la inyección de payloads personalizados para simular ataques XSS y un entorno controlado para evaluar la vulnerabilidad sin afectar la aplicación en producción. Al realizar estas pruebas, se pueden detectar y corregir vulnerabilidades críticas, mejorar la seguridad general de la aplicación, cumplir con requisitos normativos y regulatorios y proteger los datos sensibles de los usuarios. Además, la integración de estas pruebas en el proceso de desarrollo y mantenimiento de aplicaciones web es esencial para asegurar una seguridad robusta y confiable, permitiendo a los profesionales de la seguridad estar siempre un paso adelante de los atacantes y garantizar la confianza de los usuarios en la aplicación.

Referencias.

Acunetix Web Vulnerability Scanner - Test websites. (s. f.). <http://www.vulnweb.com/>